

3



Módulo 03

Técnicas Utilizadas na Identificação de Ameaças

Aula 02

Scanner de Vulnerabilidades

Introdução —

Nesta aula serão abordados os seguintes conceitos:

- Reconhecimento ativo e passivo e suas técnicas;
- *Pen Test* ou Teste de Penetração: finalidade e importância;
- Ciclo de vida do ataque de *Pen Test*.

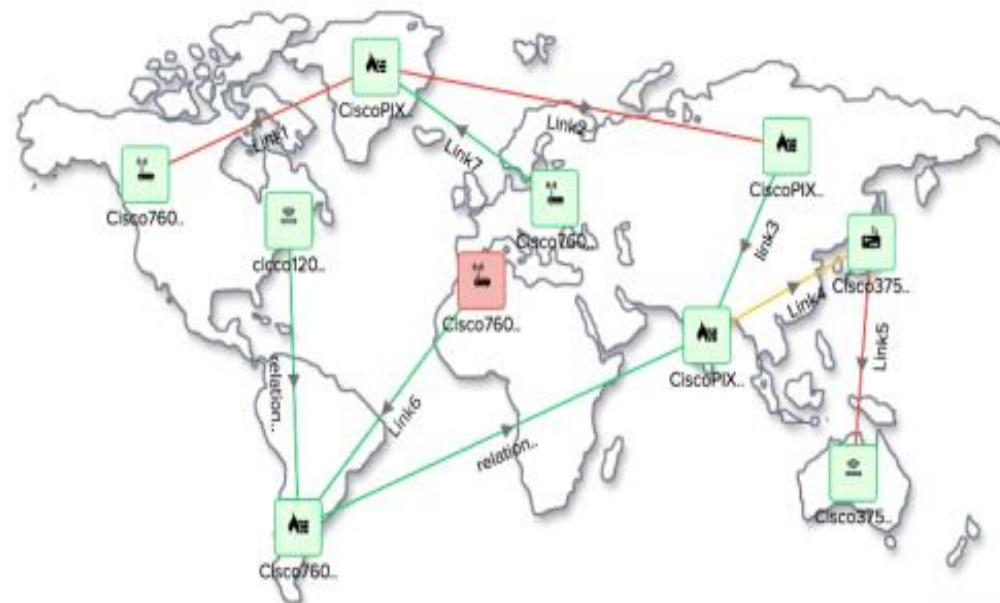
Aula 02

Scanner de Vulnerabilidades

Reconhecimento Ativo vs. Passivo —

RECONHECIMENTO ATIVO VS. PASSIVO

- É o primeiro passo em qualquer avaliação de segurança cibernética.
- Acontece antes de um atacante ou profissional de segurança explorar uma rede ou sistema.
- Trata-se da coleta de informações sobre o alvo da avaliação ou do ataque.
- Há duas abordagens distintas:
 1. Reconhecimento Ativo.
 2. Reconhecimento Passivo.

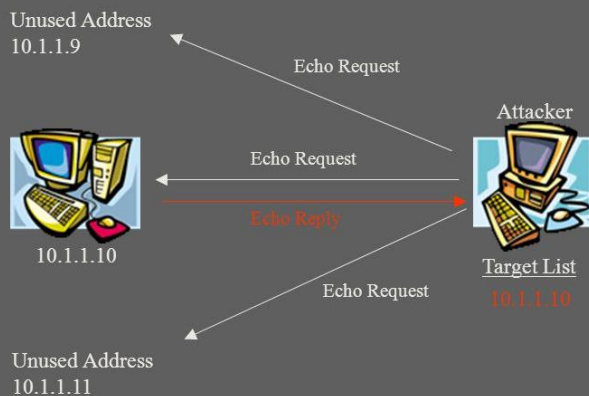


Fonte: Site24x7

Disponível em: <<https://www.site24x7.com/pt/network-mapping.html>>.

Acesso em: 21 mar. 2024.

PING Sweeps



Fonte: SlidePlayer, 2017.
Disponível em: <<https://slideplayer.com/slide/6055181/>>.
Acesso em: 21 mar. 2024.

RECONHECIMENTO ATIVO

- Envolve a interação direta com o alvo.
- Pode gerar tráfego.
- Pode ser detectado pelos sistemas ou equipes de segurança.
- Equivale a "bater à porta" do alvo para ver como ele responde.
- Alguns exemplos:
 - Varreduras de portas,
 - Solicitações de DNS,
 - Ping sweeps.*

RECONHECIMENTO ATIVO

- Vantagens:

- Fornece informações detalhadas e em tempo real.
- É útil para testar a resiliência do alvo a varreduras ativas.

- Desvantagens:

- Pode ser invasivo e perturbar as operações normais.
- Pode ser detectado pelo alvo.

PING SWEEP

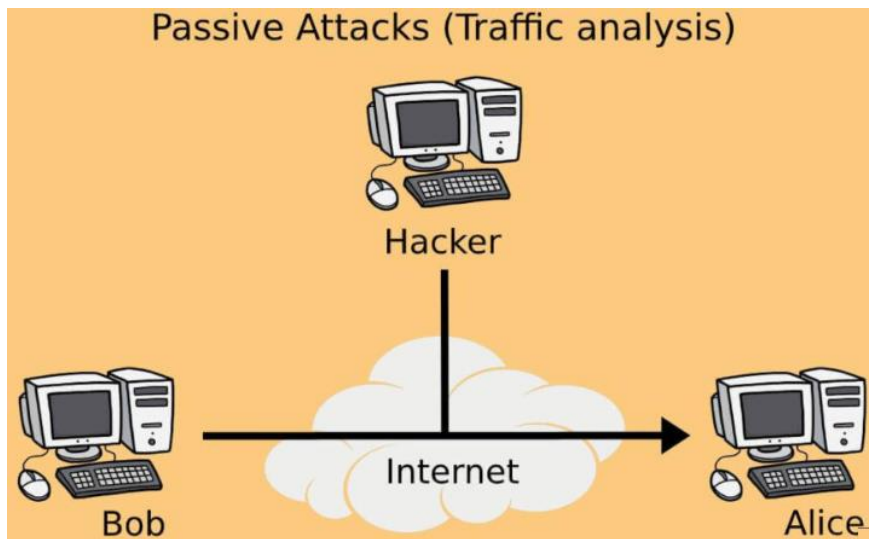
```
root@kali:~/Desktop# nmap -sn 192.168.1.1/24
Starting Nmap 7.80 ( https://nmap.org ) at 2020-05-25 20:36 EDT
Nmap scan report for XiaoQiang (192.168.1.1)
Host is up (0.00097s latency).
MAC Address: 50:64:2B:CB:20:1B (Xiaomi Electronics,co.)
Nmap scan report for 192.168.1.2
Host is up (0.00017s latency).
MAC Address: 70:85:C2:8E:72:13 (ASRock Incorporation)
Nmap scan report for 192.168.1.3
Host is up (0.0081s latency).
MAC Address: 1C:66:6D:99:B3:7D (Hon Hai Precision Ind.)
Nmap scan report for 192.168.1.22
Host is up (0.00024s latency).
MAC Address: 08:00:27:3A:7F:3F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.38
Host is up (0.00027s latency).
MAC Address: 08:00:27:DC:12:61 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.51
Host is up.
```

Fonte: Youtube, 2020.

Disponível em:

<<https://www.youtube.com/watch?app=desktop&v=LvCdaftsMwI>>.

Acesso em: 21 mar. 2024.



Fonte: OneProxy.

Disponível em: <<https://oneproxy.pro/wiki/passive-attack/>>.

Acesso em: 21 mar. 2024.

RECONHECIMENTO PASSIVO

- Envolve a coleta de informações sem interação direta com o alvo.
- Geralmente passa despercebido e não perturba o alvo.
- Pode fornecer informações menos detalhadas.
- Exemplos: Monitoramento de tráfego de rede, Análise de logs, Pesquisa OSINT (*Open Source Intelligence*).

RECONHECIMENTO PASSIVO

— Vantagens:

- Geralmente passa despercebido e não perturba o alvo.
- É útil para coletar informações gerais sobre a infraestrutura do alvo.

— Desvantagens:

- Pode fornecer informações menos detalhadas e mais antigas.
- Não é ideal para identificar vulnerabilidades específicas.



Fonte: Medium, 2023.

Disponível em:

<<https://medium.com/@ronak.d.sharma111/an-introduction-to-maltego-and-its-use-of-osint-5146e8f1e66f>>.

Acesso em: 21 mar. 2024.

Aula 02

Scanner de Vulnerabilidades

Teste de Penetração (*Pen Test*)

TESTE DE PENETRAÇÃO (*PEN TEST*)

- Trata-se da realização de um ataque simulado a sistema, rede ou aplicação.
- Esse tipo de ataque é controlado e faz parte da estratégia de segurança.
- Permitem que as organizações tomem medidas proativas para mitigar riscos.
- A ética e a conformidade em testes de penetração são fundamentais.
- Isso inclui o respeito às leis e regulamentações, autorização adequada, notificação às partes interessadas e documentação.

TESTE DE PENETRAÇÃO (*PEN TEST*)

Objetivos claros:

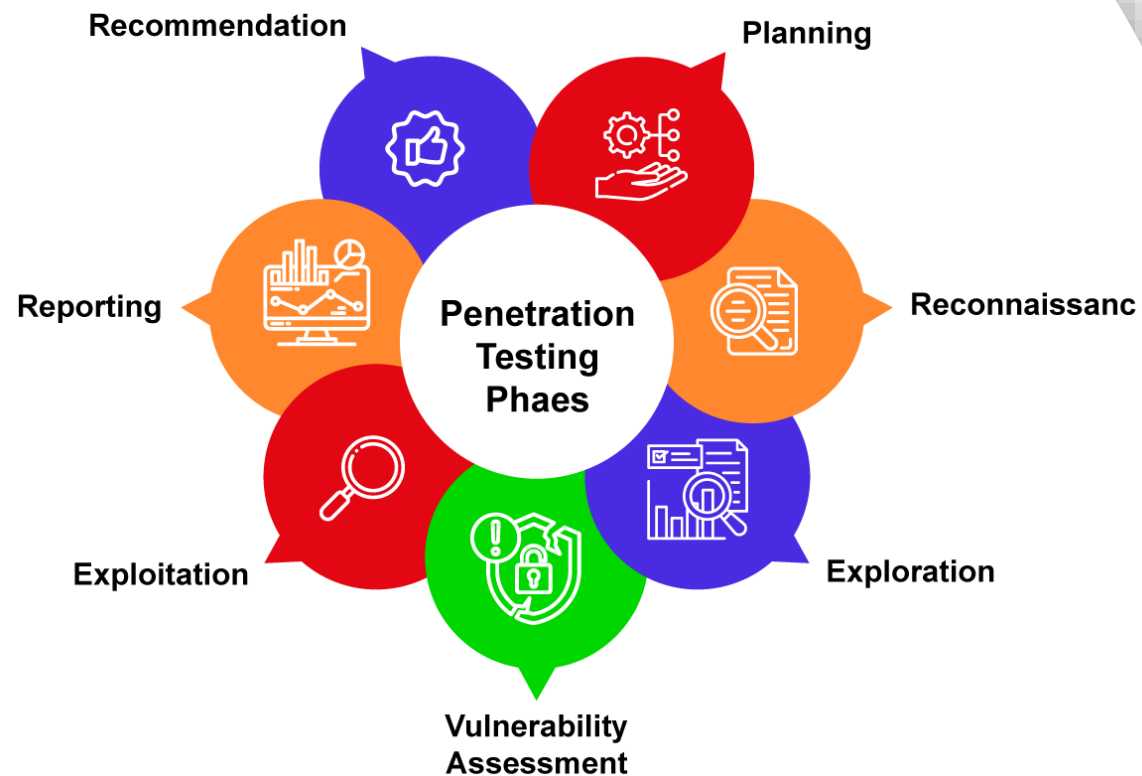
- Mapear pontos fracos em sistemas, redes e aplicativos.
- Avaliar a eficácia das medidas de segurança existentes
- Medir a capacidade de resposta da organização.
- Fornecer recomendações.



Fonte: Successive.Cloud.

Disponível em: <<https://successive.cloud/penetration-testing-phases/>>.

Acesso em: 21 mar. 2024.



TESTE DE PENETRAÇÃO (*PEN TEST*)

— Fases de um *Pen Test*:

1. Planejamento;
2. Coleta de informações;
3. Análise;
4. Exploração;
5. Documentação;
6. Relatório.

Fonte: ResearchGate, 2019.

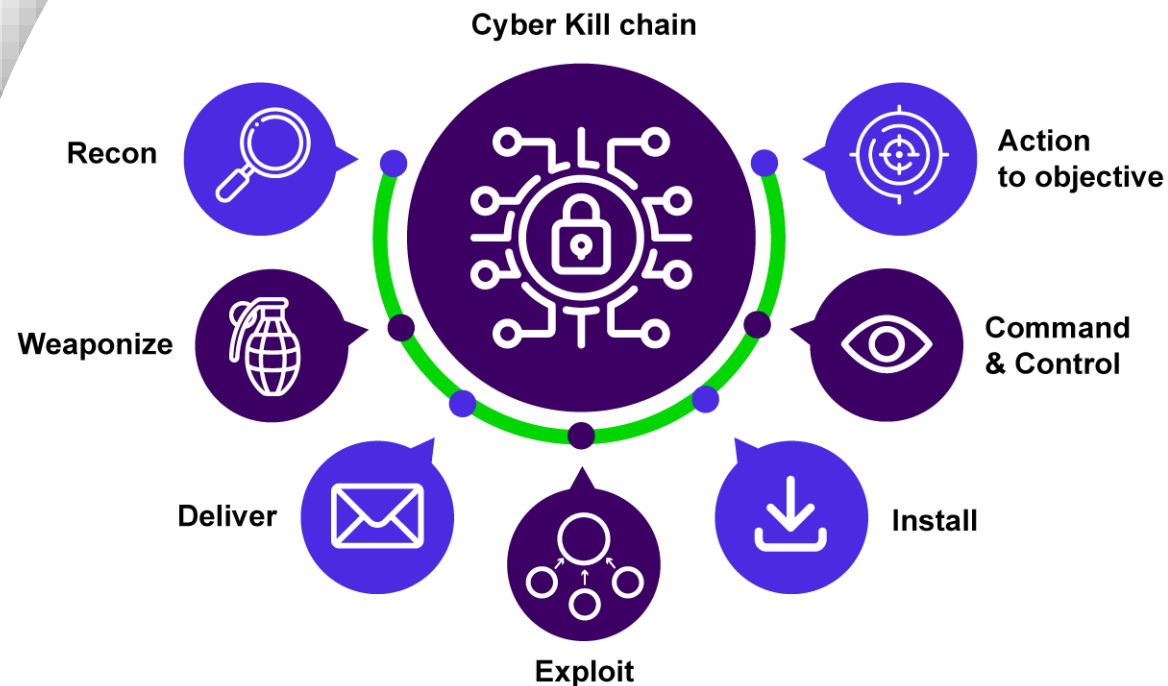
Disponível em: <https://www.researchgate.net/figure/Fig-Phases-of-Penetration-Testing-12_fig1_349077887>.

Acesso em: 21 mar. 2024.

TESTE DE PENETRAÇÃO (PEN TEST)

— Ciclo de vida de um *Pen Test* utilizando uma *kill chain* estruturada:

1. Reconhecimento;
2. Exploração;
3. Persistência;
4. Escalonamento de privilégios;
5. Movimento lateral/pivotagem;
6. Ações baseadas em objetivos;
7. Fases de limpeza.



Fonte: Adobe Stock.

Disponível em: <<https://stock.adobe.com/br/images/cyber-kill-chain/183497530>>.

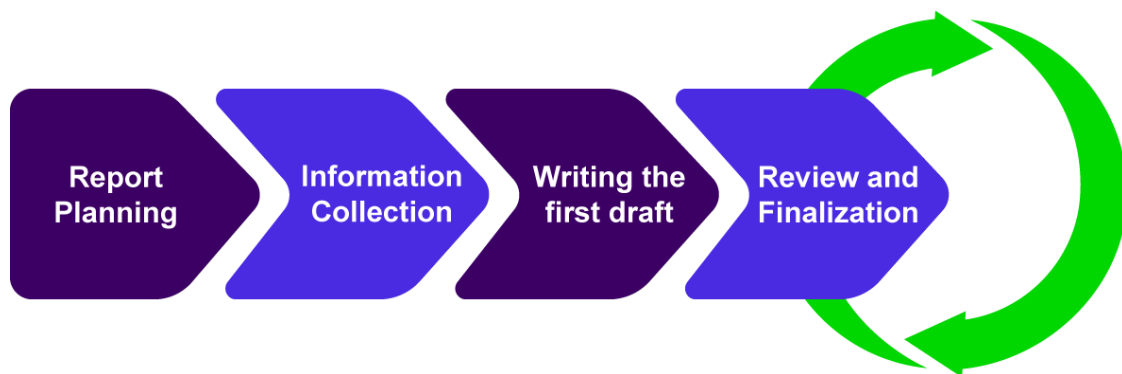
Acesso em: 21 mar. 2024.



Fonte: Tutorialspoint.
Disponível em:
<https://www.tutorialspoint.com/penetration_testing/penetration_testing_report_writing.htm>.
Acesso em: 21 mar. 2024.

TESTE DE PENETRAÇÃO (*PEN TEST*)

- Importância de relatórios detalhados e documentação:
 - Os relatórios registram as atividades realizadas e fornecem informações para tomada de decisão quanto à melhoria contínua na segurança cibernética.
 - Estrutura dos relatórios:
 1. Visão geral do escopo do teste.
 2. Detalhes das atividades realizadas em cada fase.



Fonte: Mir Ali Shahidi Ethical Hacker.
Disponível em: <<https://www.miralishahidi.ir/resources/writing-penetration-testing-report-33343.pdf>>.
Acesso em: 21 mar. 2024.

TESTE DE PENETRAÇÃO (*PEN TEST*)

3. Vulnerabilidades identificadas e seu impacto.
4. Recomendações para mitigação.
5. Evidências que comprovem as descobertas.
6. Informações sobre a conformidade com as regras de engajamento.
7. Uma análise de riscos e impacto.

3



Você chegou ao final da Aula 02
Scanner de Vulnerabilidades